NORTHFIELD UNIVERSITY | OFFICE OF INFORMATION TECHNOLOGY

Password and Credential Management Policy

Field	Detail
NUOIT Policy Number	2023-IAM-01
Title	Password and Credential Management Policy
Effective Date	August 1, 2023
Version	4.0
Last Reviewed	June 15, 2023
Policy Owner	Chief Information Security Officer (CISO)
Approved By	Vice Provost for Information Technology
Supersedes	Version 3.2 (September 1, 2021)
Classification	Public — Internal Distribution

1.0 Purpose

The purpose of this policy is to establish requirements for the creation, management, protection, and rotation of passwords and credentials used to access Northfield University information systems, applications, and services. Strong password practices are a foundational element of the university's information security posture and are essential to safeguarding institutional data, research assets, and personally identifiable information (PII).

2.0 Scope

This policy applies to all members of the Northfield University community, including but not limited to:

- Full-time and part-time faculty
- Administrative and classified staff
- Undergraduate and graduate students
- Temporary employees, contractors, and consultants
- Visiting scholars and affiliates
- Automated service accounts and system-to-system integrations

All university-issued accounts — including NetID credentials, email accounts, VPN accounts, administrative and privileged accounts, and service accounts — are governed by this policy regardless of the system, platform, or application in which they are used.

3.0 Password Construction Standards

3.1 Password Complexity

All passwords associated with Northfield University accounts must meet the following minimum complexity requirements:

- Passwords must be a **minimum of 12 characters** and include at least one uppercase letter, one lowercase letter, one digit, and one special character (e.g., !, @, #, $, %, ^, &, *).
- Passwords **must not** contain the user's NetID, first name, last name, date of birth, or any other easily guessable personal identifier.
- Passwords **must not** consist of a single dictionary word in any language, even if modified with simple substitutions (e.g., "P@ssw0rd" is prohibited).
- Passwords **must not** match any entry on the NUOIT-maintained list of commonly compromised passwords, which is updated quarterly from public breach databases.

3.2 Passphrase Guidance

While not required under this version of the policy, users are encouraged to consider passphrases — sequences of four or more unrelated words — as an alternative to traditional complex passwords. Passphrases that meet the 12-character minimum and include the required character classes are acceptable.

3.3 Prohibited Practices

The following practices are explicitly prohibited:

- Using the same password across multiple university systems or between university and personal accounts.
- Sharing passwords with any other individual, including supervisors, IT staff, or help desk personnel. No Northfield University employee will ever request your password.
- Writing passwords on paper, sticky notes, whiteboards, or any other physical medium stored in or near the workspace.
- Storing passwords in unencrypted files, spreadsheets, email messages, or browser auto-fill without an approved password manager.

4.0 Password Lifecycle Management

4.1 Password Expiration

All university accounts — including student, faculty, staff, and service accounts — **must change passwords every 90 days**. Accounts that fail to rotate credentials within the 90-day window will be automatically locked and require manual reactivation by the IT Service Desk. Password history enforces a minimum of **12 unique passwords** before reuse is permitted.

Users will receive email notifications at 14 days, 7 days, and 1 day prior to password expiration. Notifications are sent to the user's primary Northfield University email address and, where registered, via SMS to the user's mobile device.

4.2 Password Reset Procedures

Password resets may be initiated through the following authorized channels:

1. **Self-Service Portal** — Users may reset their own password at https://identity.northfield.edu/reset (https://identity.northfield.edu/reset) after verifying their identity through security questions and a one-time code sent to their registered recovery email or mobile number.
2. **IT Service Desk** — Users may contact the IT Service Desk by phone at (555) 274-4357 or in person at the Technology Commons, Room 102. Identity verification requires presentation of a valid Northfield University ID card or answers to pre-registered security questions.
3. **Departmental IT Liaisons** — Authorized departmental IT staff may submit password reset requests on behalf of users through the NUOIT ticketing system, provided the request includes documented identity verification.

4.3 Account Lockout

After **five (5) consecutive failed login attempts**, the account will be temporarily locked for a period of 30 minutes. If additional failed attempts occur after the lockout period expires, the lockout duration doubles with each subsequent cycle, up to a maximum of 24 hours. Persistent lockouts are flagged for review by the Security Operations Center (SOC) as potential brute-force attack indicators.

5.0 Multi-Factor Authentication

5.1 Current Status

As of the effective date of this policy, multi-factor authentication (MFA) is **available but not universally mandated** across all Northfield University systems. MFA is currently required for the following:

- Access to the NUOIT Administrative Console and privileged system accounts
- Remote VPN connections originating from off-campus networks
- Access to systems classified as containing **High-Risk Data** under the Northfield University Data Classification Policy (Policy No. 2022-GOV-03)

5.2 Supported MFA Methods

The university supports the following second-factor authentication methods through the Northfield University Identity Platform:

Method	Description	Availability
Authenticator App	Time-based one-time passwords (TOTP) via approved apps (e.g., Google Authenticator, Microsoft Authenticator)	All users
SMS One-Time Code	Six-digit code sent to the registered mobile number	All users
Hardware Token	University-issued FIDO2/U2F security key	Faculty, staff, and administrators
Push Notification	Approve/deny prompt via the Northfield Authenticator mobile app	All users

5.3 MFA Enrollment

Users who are required to use MFA or who voluntarily opt in must enroll at least **two (2)** distinct second-factor methods to ensure availability in the event that one method is unavailable (e.g., lost phone). Enrollment is managed through the Identity Portal at https://identity.northfield.edu/mfa (https://identity.northfield.edu/mfa).

5.4 Voluntary MFA Adoption

All members of the university community are **strongly encouraged** to enable MFA on their accounts, even where it is not currently mandated. The Office of Information Technology periodically conducts awareness campaigns promoting voluntary MFA enrollment through the annual Cybersecurity Awareness Month program and new-student orientation sessions.

6.0 Credential Storage and Approved Tools

6.1 Approved Password Managers

Users who need to store multiple credentials are required to use a university-approved password management solution. The following tools are currently approved:

- **Northfield Vault** (institutionally licensed, recommended) — Available to all faculty, staff, and students at no cost via the NUOIT Software Portal.
- **1Password Teams** — Approved for departmental use where a valid departmental license is maintained.
- **Bitwarden** — Approved for individual use; users are responsible for their own licensing.

Use of any password manager not listed above requires prior written approval from the Information Security Office.

6.2 Credential Storage Prohibitions

Credentials must **never** be stored in:

- Plain-text files, scripts, or source code repositories (including `.env` files committed to version control)
- Shared drives, Google Docs, or collaboration platforms without encryption
- Email messages (sent or drafts) or calendar entries
- Browser built-in password managers on shared or public workstations

6.3 Developer and Application Credentials

Application developers and system administrators must use the university's centralized secrets management platform (**Northfield Secrets Vault**, based on HashiCorp Vault) for storing API keys, database credentials, certificates, and other machine-to-machine secrets. Hardcoding credentials in application source code is a **violation of this policy** and may result in disciplinary action as outlined in Section 8.0.

7.0 Service Account and Privileged Account Standards

7.1 Service Account Passwords

Service accounts — automated accounts used for application-to-application communication, scheduled tasks, or system integrations — are subject to the following requirements:

- Service account passwords must be a **minimum of 24 characters** and generated using a cryptographically secure random generator.
- Service account passwords must be rotated **every 90 days**, consistent with the standard rotation schedule defined in Section 4.1.
- Service account credentials must be stored exclusively in the Northfield Secrets Vault and must not be known to individual users in plain text.
- Each service account must have a designated **human account owner** listed in the NUOIT Service Account Registry who is responsible for ensuring compliance with this policy.

7.2 Privileged Account Standards

Users with privileged access (e.g., system administrators, database administrators, network engineers) must adhere to the following additional requirements:

- Privileged account passwords must be a **minimum of 20 characters** and meet all complexity requirements specified in Section 3.1.
- Privileged accounts must use **multi-factor authentication** for all interactive logons (see Section 5.1).
- Privileged credentials must be stored in the Northfield Secrets Vault or an equivalent approved privileged access management (PAM) solution.
- Privileged accounts must not be used for routine, non-administrative tasks such as reading email or browsing the web.

7.3 Shared Credentials

The use of shared credentials is **prohibited** except where explicitly approved in writing by the CISO. Approved exceptions must be documented in the NUOIT Shared Credential Exception Register and reviewed annually. All shared credential exceptions must employ compensating controls including audit logging, access restriction by IP address, and mandatory MFA.

8.0 Enforcement and Sanctions

Violations of this policy may result in one or more of the following actions:

- Temporary or permanent suspension of network and system access privileges
- Mandatory completion of remedial cybersecurity training
- Referral to the appropriate disciplinary body (e.g., Office of Student Conduct for students, Human Resources for staff, the Provost's Office for faculty)
- In cases involving negligence or willful misconduct resulting in a data breach, potential civil or legal liability

The Office of Information Technology reserves the right to disable or force-reset any password that is determined to be non-compliant with this policy, with or without prior notice to the account holder.

9.0 Related Policies and References

- Northfield University Data Classification Policy (Policy No. 2022-GOV-03)
- Northfield University Acceptable Use Policy (Policy No. 2023-GOV-01)
- Northfield University Incident Response Plan (Policy No. 2023-SEC-02)
- NIST Special Publication 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management
- CIS Controls v8 — Control 5: Account Management

10.0 Revision History

Version	Date	Author	Changes
4.0	August 1, 2023	Information Security Office	Updated complexity requirements to 12-character minimum; expanded service account standards; added approved password manager list
3.2	September 1, 2021	Information Security Office	Added MFA section; updated lockout thresholds
3.0	March 15, 2020	Information Security Office	Major revision — aligned with NIST 800-63B guidelines
2.1	January 10, 2018	Information Security Office	Added passphrase guidance
2.0	July 1, 2016	IT Policy Committee	Comprehensive rewrite
1.0	September 1, 2013	IT Policy Committee	Initial release

Synthetic document for a take-home assignment. Not an official NYU policy. | Northfield University Office of IT